

APP DEVELOPER HANDOVER

Dream Drive

Customer app | screens, flows, central API

The app owns frontend screens and navigation.
All prices, availability, KYC, payments, and booking status
come from the live /v1 API. Do not invent business rules
on the device.

API prefix	/v1
Auth	Authorization: Bearer <token>
Money	integer paise Time UTC in, IST on screen
Realtime	Socket.IO {SOCKET_URL}/booking + HTTP poll

Fill live-api.config.json with HTTPS URLs before sharing this pack.
Updated 5 Sep 2026

1. Who does what

Share one HTTPS API with the app team. They never call admin routes, internal routes, or write the database. You run KYC review, Razorpay webhooks, Leegality, and fleet ops.

App developer

Screens, UX, navigation
Razorpay Checkout UI
Push token, deep links
Display API data
Form UX (API still validates)

API owner

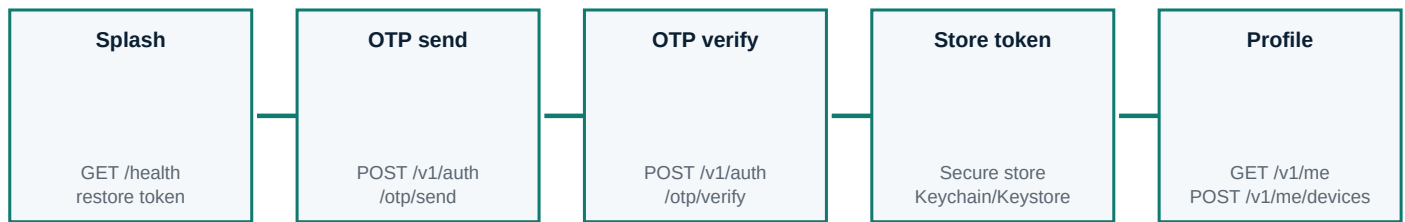
Live /v1 API + socket
Prices, holds, refunds
KYC decision, e-sign
Webhooks, email OTP
Admin panel / fleet

2. Connect

- Base URL from live-api.config.json (HTTPS). Health: GET /health
- Public: /v1/public/** and auth login/otp/register/google
- Everything else: Bearer token (OTP session dd1.* or Firebase ID token)
- OTP: 3 sends / 15 min / IP, code lives 5 minutes
- Errors: read message or error. Some bodies return {error} with HTTP 200 - check it.
- Native apps skip CORS. Expo web needs CORS_ORIGINS on the API.

3. Auth flow

Preferred path is email OTP. Password and Google are also live.

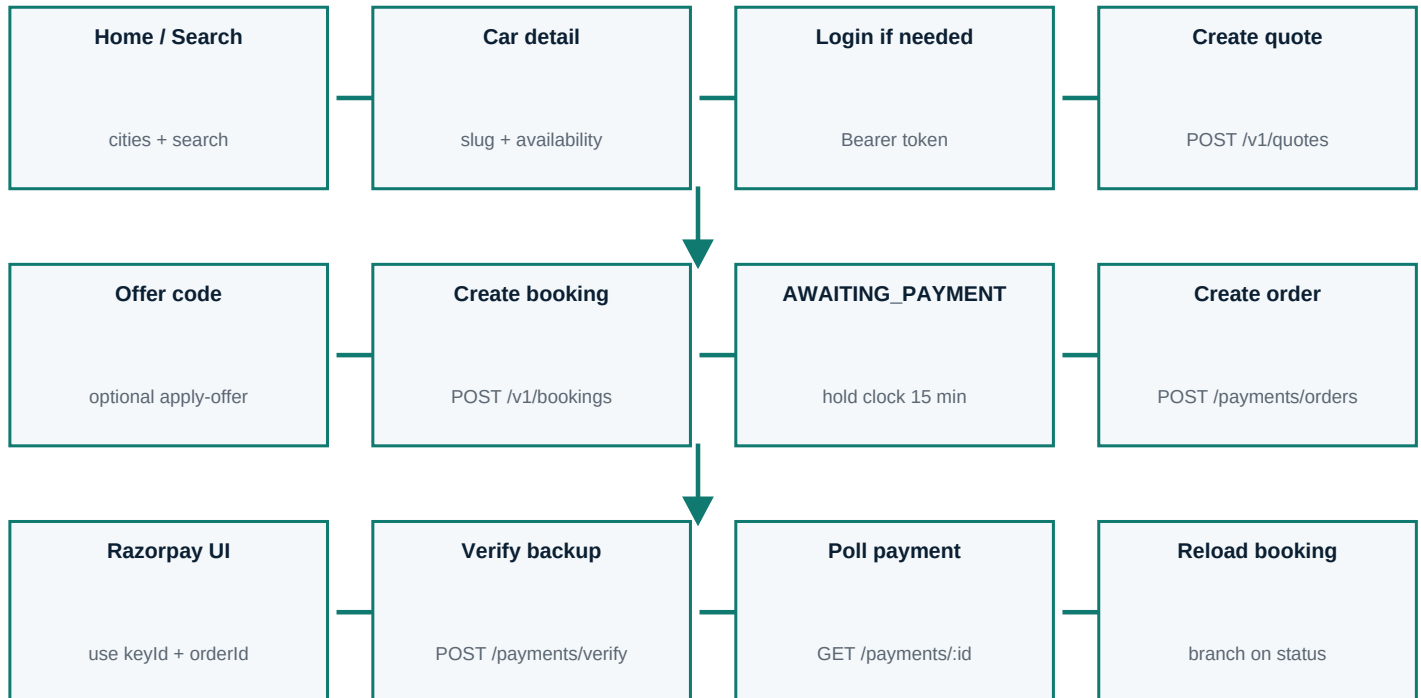


- POST /v1/auth/login { email, password } -> Firebase ID token
- POST /v1/auth/register password min 8 chars
- POST /v1/auth/google { idToken }
- PATCH /v1/me phone change requires a second OTP then POST /v1/me/phone/verify
- dev:email tokens work only when NODE_ENV is not production

401 Sign in required -> clear session. 401 Account disabled -> banned copy, no retry.

4. Search -> pay (core money path)

The device never calculates hire. Quote freezes price (~20 min). Booking holds a vehicle (~15 min). Razorpay success is not enough - poll payment until SUCCESS.

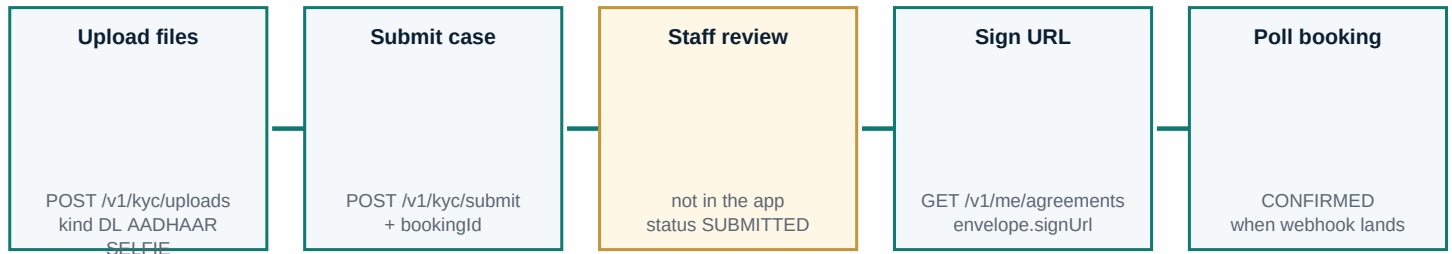


Hard rules

- amountPaise and depositPaise from the quote/order only. Format paise / 100 as INR.
- If quote.expired or hold lapses, start a new quote. Do not reuse stale ids.
- Same quoteId posted twice returns the existing booking (idempotent).
- kind TOKEN | BALANCE | DEPOSIT. Customers typically pay TOKEN first.
- If orders.mock is true, staging may skip the Razorpay SDK.

5. Self-drive KYC + e-sign

After token payment, self-drive usually becomes `AWAITING_KYC`. Staff approve in admin. The app only uploads, submits, and opens Leegality. Closing a WebView is not a signature.



- Self-drive required: driving licence + (Aadhaar or address proof) + selfie with ID.
- PDF / JPG / PNG / WebP, max 8 MB.
- Aadhaar 12 digits, PAN ABCDE1234F, DL must cover drop-off. API stores hashes, last4 only.
- If GET /v1/me/kyc reusable=true, submit bookingId with empty documents.
- NEEDS_REUPLOAD: only that kind again. Show notes from the case.

With-driver / airport / tour may skip KYC and jump to CONFIRMED after pay. Still poll the booking; do not hard-code the next screen.

6. Booking status machine

Render the status the API returns. Suggested customer CTAs:

AWAITING_PAYMENT Pay now hold timer	AWAITING_KYC Upload documents
AWAITING_SIGNATURE Open agreement	CONFIRMED Dates, branch, driver
HANDOVER / ONGOING Trip live cancel off	RETURN_PENDING Return in progress
COMPLETED Review CTA	CANCELLED / NO_SHOW Refund / book again

7. Track + cancel + support

- Logged in: GET /v1/me/bookings then GET /v1/bookings/:id (id or publicId).
- Socket: io(SOCKET_URL/booking) emit booking:subscribe on booking:status then refetch.
- Always poll GET booking every ~8 seconds if the socket drops.
- Guest: POST /v1/public/bookings/track/otp then /track/verify (phone must match profile).
- Cancel: POST /v1/bookings/:id/cancel until handover. Show refundPct from the response.
- Tickets: POST /v1/me/tickets | CLOSED tickets cannot be replied to.

Refund bands (server): self-drive 100% if >= 48h before start, 50% if >= 24h, else 0. Airport 12h / 3h. Tour 72h / 24h. Subscription 7 days / 48h. Display policy before confirm.

8. Screens the app must ship

1. Splash / force-update
2. Login OTP, password, Google, register
3. Home (banners, featured cars, call/WhatsApp)
4. City + date + rental-type search
5. Results + filters + availability
6. Car detail + calendar busyDays
7. Checkout from quote (no local math)
8. Razorpay + payment poll
9. KYC upload / submit
10. Agreement + Leegality
11. My bookings + detail + live status
12. Guest track
13. Profile, addresses, phone OTP
14. Invoices PDF, wallet read-only
15. Support tickets
16. Packages, subscriptions
17. Contact, legal CMS pages
18. Review after COMPLETED

Out of scope

- Admin panel, partner portal, delivery-executive app
- Approving KYC, assigning cars/drivers, capturing deposits
- Calling /v1/admin or /internal

9. What you send with the live API

- HTTPS API URL and socket URL in live-api.config.json
- Whether Razorpay is live or mock
- A test customer email that can receive OTP
- Proof that GET /health and public search return cars
- Firebase SHA-1 / iOS client ids for Google Sign-In on devices
- Support contact for outages
- Do not send database URLs, Razorpay secret, Leegality keys, INTERNAL_TOKEN

10. App go-live

- Store builds use the live HTTPS URL, not localhost
- UAT: pay, kill app, reopen - booking follows webhook status
- Quote expiry and hold expiry handled
- Deep links dreamdrive://bookings/:id and dreamdrive://track/:publicId
- POST /v1/me/devices after login
- Never log tokens, OTP, Aadhaar, or PAN

Source of truth

If the UI and the API disagree, the API wins. Rebuild the screen from GET /v1/bookings/:id. Full request/response contract: 03-api-contract.md Requirements: 05-requirement-sheet.md